

TechCorp

Compliance & Data Governance Guidelines v2.1

Classification: Confidential | Owner: Legal & Compliance Team | Review Date: Dec 2025

1. GDPR Compliance

1.1 Lawful Basis for Processing

TechCorp processes personal data of EU residents under the following lawful bases as defined by GDPR Article 6: (a) Contractual necessity for service delivery, (b) Legitimate interest for security monitoring and fraud prevention, (c) Consent for marketing communications. Consent is obtained at signup and can be withdrawn at any time via account settings.

1.2 Data Subject Rights

EU data subjects have the following rights which TechCorp fulfills within 30 days of verified request:

- Right to Access: Request a copy of all personal data held about you (Article 15)
- Right to Rectification: Correct inaccurate personal data (Article 16)
- Right to Erasure: Delete your account and all associated data - 'Right to be Forgotten' (Article 17)
- Right to Portability: Export data in machine-readable format - JSON or CSV (Article 20)
- Right to Restriction: Pause processing while a dispute is under review (Article 18)
- Right to Object: Opt out of processing for legitimate interest purposes (Article 21)

1.3 Data Transfers

Cross-border transfers outside the EU/EEA are governed by Standard Contractual Clauses (SCCs) adopted by the European Commission. TechCorp's US data centers are covered under the EU-US Data Privacy Framework. Customers may request a copy of SCCs at legal@techcorp.com.

2. Data Retention Policy

Data Type	Retention Period	After Retention	Legal Basis
User account data	Subscription + 90 days	Automated deletion	Contract
Uploaded documents	Subscription + 90 days	Automated deletion	Contract
Audit logs	2 years	Automated deletion	Legitimate interest
Billing records	7 years	Archived, not deleted	Legal obligation
Support tickets	3 years	Anonymized	Legitimate interest
Marketing data	Until consent withdrawn + 30 days	Automated deletion	Consent
Security logs	1 year	Automated deletion	Legitimate interest
Backup snapshots	30 days rolling	Automated deletion	Contract

3. Security Protocols

3.1 Encryption

All data at rest is encrypted using AES-256. Data in transit uses TLS 1.3 with perfect forward secrecy. Database backups are encrypted with separate keys stored in AWS KMS (Key Management Service). Encryption keys are rotated annually or immediately upon any suspected compromise.

3.2 Access Controls

Production systems follow the principle of least privilege. Engineers require MFA and VPN to access production environments. All production access is logged and reviewed monthly. Direct database access requires dual approval via our PAM (Privileged Access Management) system. SSH uses certificate-based authentication with 8-hour expiry.

3.3 Vulnerability Management

TechCorp conducts quarterly penetration tests via a third-party security firm. Critical vulnerabilities (CVSS 9.0+) are patched within 24 hours, high (7.0-8.9) within 7 days, medium within 30 days. We operate a bug bounty program at techcorp.com/security/bounty with rewards up to \$10,000.

3.4 Incident Response

Security incidents are classified as P0-P3 by severity. P0 (active breach) triggers immediate containment within 15 minutes and executive escalation. Affected customers are notified within 72 hours as required by GDPR Article 33. Annual incident response drills are conducted and results documented.

4. Data Processing Agreement (DPA)

A Data Processing Agreement is available for all Enterprise customers and Business plan customers processing EU personal data. The DPA covers: data processor obligations, complete sub-processor list, technical and organizational security measures, audit rights, and breach notification procedures. Request at legal@techcorp.com.

5. Sub-Processors

Sub-Processor	Purpose	Location	Compliance
AWS	Cloud infrastructure & storage	US / EU / AP	ISO 27001, SOC 2 Type II
Stripe	Payment processing	US	PCI DSS Level 1
Sendgrid	Transactional email	US	SOC 2 Type II
Datadog	Monitoring & logging	US	SOC 2 Type II
OpenAI	AI features (Enterprise opt-in only)	US	SOC 2 Type II
Cloudflare	CDN & DDoS protection	Global	ISO 27001, SOC 2
PagerDuty	Incident alerting	US	SOC 2 Type II

6. Compliance Certifications

Certification	Scope	Last Audit	Certificate Available
SOC 2 Type II	All production systems	November 2024	Yes - via NDA

ISO 27001	Information security management	August 2024	Yes - public
GDPR	EU personal data processing	Ongoing	DPA available
HIPAA	Healthcare data (Enterprise)	September 2024	BAA available
CCPA	California consumer data	Ongoing	Privacy policy
PCI DSS	Payment card data (via Stripe)	December 2024	Stripe certified